COMPTIA SECURITY+ SY0-701 | DOMAIN 3 · SECURITY ARCHITECTURE (18%)

# Security+ 3.2 · Secure Infrastructures

Mestre CyberSec · **Lesson 3.2 — Secure Infrastructures** (5:54) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Executive Lesson Summary:** Security zones (DMZ pra público, interno atrás); attack surface (menor possível); conectividade nova = risco novo. Onde colocas cada serviço DETERMINA o quanto ele é atacado.

## 💡 Key Exam Highlights & Critical Concepts

- Zonas: DMZ separa público do interno
- Attack surface: minimiza tudo o que é acessível
- Cada nova conexão = porta nova pro atacante

## 🎯 Exam Tips & Typical CompTIA Scenarios

- 'place public services between internet and internal network' = DMZ

## 🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 3.2 — Secure Infrastructures)

**Why is this advanced coverage required for SY0-701?:** Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

**• Demilitarized Zone (DMZ)**

A network segment placed between the internet and the internal network that hosts public-facing services such as web, mail, and FTP servers. It acts as a buffer so an attacker who compromises external services has no direct access to internal systems.

⚠️ ***Exam Trap:*** *Gatilho clássico da prova: 'place public-facing services between the internet and internal network' = DMZ. No SY0-701 o termo oficial moderno é 'screened subnet' — são a MESMA coisa, nunca são respostas opostas. Não confundir com VLAN (segmentação lógica sem filtro de fluxo).*

**• Screened Subnet**

The current CompTIA terminology for what was traditionally called a DMZ: a subnet isolated between two filtering devices (e.g., two firewalls or a three-legged firewall) where external services reside. Traffic to and from the subnet is screened on both sides.

⚠️ ***Exam Trap:*** *Se a questão usar 'screened subnet', trate como sinônimo de DMZ — é o termo preferido do SY0-701. Cenário com dois firewalls ou uma interface adicional de firewall criando uma zona intermediária → screened subnet. Erraria escolhendo 'VLAN' ou 'VPN' para esse cenário.*

**• Security Zone**

A logical or physical area of the network where all devices share a common trust level, such as the internet (untrusted), DMZ (semi-trusted), and internal LAN (trusted). Traffic crossing between zones must pass through a controlled enforcement point.

⚠️ ***Exam Trap:*** *Conceito-chave: dispositivos na MESMA zona têm 'implicit trust' entre si — o problema da confiança implícita é o que motiva a segmentação. Pergunta que menciona 'trust level', 'untrusted network' ou separação internet/interno → pense em zonas de segurança e onde estão as fronteiras.*

**• Attack Surface**

The total collection of all points where an unauthorized attacker could interact with a system or network (open ports, exposed services, connections, endpoints). Effective security engineering keeps this area as small as possible.

⚠️ ***Exam Trap:*** *Lembrete da lição: cada nova conexão/serviço/porta = nova superfície de ataque = nova porta para o atacante. Se a pergunta diz 'minimize exposure' ou 'reduce the risk of new connectivity' → reduzir/a mantera attack surface*

*pequena, removendo serviços desnecessários e não expondo o que não precisa ser público.*

**• Virtual Private Network (VPN)**

An encrypted tunnel that extends a private network across an untrusted public network such as the internet. Main types: client-to-site (remote access for individual users) and site-to-site (connects entire offices), with always-on or on-demand operation.

⚠️ ***Exam Trap:*** *Distinções de prova: usuário individual acessando a rede remotamente = client-to-site / remote access VPN; conectar duas redes corporativas (matriz-filial) = site-to-site; conexão persistente e automática = always-on. Atenção ao detalhe da lição: a VPN cria nova conectividade — e nova conexão é risco novo a gerenciar.*

**• VPN Concentrator**

A dedicated device (or endpoint function) that centralizes, terminates, and manages many simultaneous VPN connections, handling encryption and decryption at scale for remote users or site-to-site links.

⚠️ ***Exam Trap:*** *Indício textual: 'many users securely connecting to one device' ou 'terminates multiple VPN tunnels' → concentrator. Cuidado com questões de vulnerability management: concentrator em fim de vida (EOL) sem patch é alvo clássico — pode aparecer combinado com 'risk' e 'legacy device'.*

**• Virtual Local Area Network (VLAN)**

A logical segmentation of devices at Layer 2 on a switch, grouping users regardless of physical location and separating broadcast domains to limit lateral movement and enforce zone separation.

⚠️ ***Exam Trap:*** *Gatilho: 'users are not in one physical location' ou 'logically separate broadcast domains' → VLAN. Distinção crítica: VLAN segrega logicamente, mas NÃO substitui DMZ/firewall nem cifra tráfego — para isolar serviços públicos de atacantes externos, a resposta é DMZ; para segmentar internamente, é VLAN.*

**• Honeypot / Honeynet**

A deliberately vulnerable decoy system (honeypot) or network/systems of decoys (honeynet) designed to attract attackers, observe their techniques, and divert them away from production assets.

⚠️ ***Exam Trap:*** *Gatilho direto: 'attract an attacker', 'decoy', 'fake vulnerable system' → honeypot; múltiplos honeypots formando uma rede de iscas → honeynet. Na arquitetura, esses alvos ficam isolados das zonas de produção — nunca dentro da rede interna confiável junto aos ativos reais.*

## 🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

### 📌 Defense-in-Depth Architectural Layering

🏠 **Real-World Analogy:** Imagine a fortified medieval citadel: it relies on no single wooden gate. It deploys an outer alligator moat, a reinforced spiked drawbridge, archers patrolling stone ramparts, thick iron portcullises, and a deep subterranean vault behind biometric locks. Breaching the outer perimeter still leaves the adversary trapped before inner defenses.

🔍 **Root Cause & Background:** No solitary security control is impenetrable. Relying solely on edge firewalls means a single user phishing exploit yields catastrophic total network compromise. Layered defense combines perimeter firewalls, network segmentation, host EDR, and data encryption to thwart lateral progression.

🛡️ **GRC Auditor Perspective:** Evaluate security control mapping against the NIST Cybersecurity Framework and CIS Top 18; verify presence of overlapping administrative, technical, and physical safeguards while enforcing Zero Trust continuous verification.

⚠️ **How CompTIA Tests This:** Trigger: 'security architecture employing multiple layered security controls so that the failure of one control does not result in compromise'. Answer: Defense-in-depth (Layered Security).

### 📌 Load Balancers: Layer 4 (Transport) vs. Layer 7 (Application)

🏠 **Real-World Analogy:** A Layer 4 Load Balancer is a parking attendant directing traffic solely by vehicle license plate and bay number: odd numbers turn left, even turn right (it reads only IP addresses and TCP/UDP ports with blazing speed, blind to interior cargo). A Layer 7 Load Balancer is a multilingual hotel concierge who greets guests, inspects their invitation letter, reads their VIP badge, and routes them based on content: '/billing' goes to the finance floor, while '/streaming' routes to video servers.

🔍 **Root Cause & Background:** Layer 4 operates strictly at TCP/UDP transport boundaries without parsing payloads. Layer 7 inspects the application layer, enabling intelligent path-based routing (e.g., /checkout vs /media), TLS termination (SSL Offloading), and cookie-based session stickiness.

🛡️ **GRC Auditor Perspective:** Audit Layer 7 load balancer TLS termination profiles; ensure cipher suites comply with modern standards (TLS 1.3) and mandate backend re-encryption to maintain continuous data-in-transit confidentiality.

⚠️ **How CompTIA Tests This:** Trigger: 'load balancer routes traffic based on HTTP request headers, cookies, or specific URL paths like /images'. Answer: Layer 7 Load Balancer. If 'routes solely based on IP address and TCP port' -> Layer 4 Load Balancer.

### 📌 Network Proxies: Forward Proxy vs. Reverse Proxy

🏠 **Real-World Analogy:** A Forward Proxy is an enterprise courier who ventures outside into city markets to fetch goods on behalf of internal executives: merchants never see the executive's identity, and the courier blocks unapproved purchases (shields internal clients going OUT to the internet). A Reverse Proxy is the frontline corporate receptionist: when outside callers dial in, she screens the caller, conceals private executive extensions, and dispatches the call (shields internal web servers receiving traffic from OUTSIDE).

🔍 **Root Cause & Background:** Forward proxies govern egress employee browsing, enforcing URL filtering, caching, and masking internal client IP schemes. Reverse proxies govern ingress consumer traffic, insulating internal web server clusters from reconnaissance, terminating TLS, and providing caching.

🛡️ **GRC Auditor Perspective:** Verify outbound URL filtering and TLS decryption compliance on corporate Forward Proxies; audit incoming HTTP security headers (HSTS, CSP, X-Frame-Options) and certificate lifecycles deployed on perimeter Reverse Proxies.

⚠️ **How CompTIA Tests This:** Trigger: 'proxy placed on the edge of the network to protect internal web servers from external client direct access'. Answer: Reverse Proxy. 'Proxy placed between corporate LAN workstations and internet to filter employee web traffic' -> Forward Proxy.

### 📌 Bastion Host / Jump Box: Hardened Gateway for Administrative Access

🏠 **Real-World Analogy:** Think of an airtight decontamination airlock guarding a Level 4 biosafety facility: no researcher steps directly from public hallways into infectious chambers wearing street clothes. They must step into the locked airlock, present biometric clearance, suit up, log the entry, and only then unlock the inner laboratory door.

🔍 **Root Cause & Background:** Exposing management services (SSH port 22 or RDP port 3389) across public subnets invites continuous dictionary attacks and automated exploit scanners. A hardened Bastion Host funnels all administrative ingress through a heavily logged gate requiring MFA.

🛡️ **GRC Auditor Perspective:** Verify that Jump Boxes enforce mandatory MFA, session recording, and automated timeout lockouts; confirm internal server firewall rules drop all administrative management packets that do not originate from the Jump Box IP.

⚠️ **How CompTIA Tests This:** Trigger: 'hardened intermediate server placed in a perimeter DMZ used as a sole transit point for administrators to manage isolated internal systems'. Answer: Bastion Host / Jump Box.

## ⚡ QUICK-REFERENCE EXAM CHEAT SHEET

| Typical Exam Scenario / Practical Situation | Technical Concept & Target Answer |
|---|---|
| Security architectural doctrine implementing overlapping controls so no single point of defensive failure leads to breach | **Defense-in-Depth** |
| Load balancing appliance making routing decisions based on HTTP headers, URI resource paths, and application cookies | **Layer 7 Load Balancer (Application Load Balancer)** |
| Perimeter gateway intercepting incoming public client requests to shield internal web servers, terminate TLS, and cache | **Reverse Proxy** |
| Internal gateway routing and inspecting outbound employee web traffic to enforce acceptable use and content filtering | **Forward Proxy** |
| Dedicated, hardened bridge server positioned in a DMZ acting as the mandatory staging conduit for remote administration | **Bastion Host / Jump Box** |
| Process of terminating cryptographic SSL/TLS handshakes on the load balancer to reduce CPU utilization on web backends | **SSL/TLS Offloading** |

## ✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

**QUESTION 1 · EXAM SCENARIO**

**A retail company runs a public e-commerce site that must be reachable from the internet, but its customer database must remain unreachable directly from outside. The security architect needs to place the web server so that a compromise is less likely to expose the database. Where should the web server be deployed?**

**A)** On the internal server VLAN with the database

**B)** In a screened subnet, with firewall rules allowing only required application traffic to the database

**C)** On the management VLAN used by domain controllers

**D)** In the same VPN address pool used by remote employees

**QUESTION 2 · EXAM SCENARIO**

**After a new remote administration feature is released, administrators can reach it from any internet address. The CISO wants to reduce the attack surface without losing administrative access. Which action BEST meets this goal?**

**A)** Publish the portal on all public IP addresses but require a long password

**B)** Restrict the portal to the management network or VPN and close unnecessary public inbound ports

**C)** Keep the portal public but add a web application firewall in monitor-only mode

**D)** Increase logging on the portal and review logs weekly

**QUESTION 3 · EXAM SCENARIO**

**A company has hundreds of remote workers who need encrypted access to internal applications. The network team wants a dedicated appliance to terminate many VPN tunnels, authenticate users, and route traffic into the internal network. Which component should they deploy?**

**A)** VPN concentrator

**B)** Honeynet

**C)** Screened subnet

**D)** VLAN trunk

**QUESTION 4 · EXAM SCENARIO**

**The security team wants to create a controlled environment that appears to contain vulnerable servers, so analysts can observe attacker behavior and generate early alerts without affecting production. Which infrastructure component should they implement?**

**A)** Honeynet

**B)** VPN concentrator

**C)** Screened subnet

**D)** Management VLAN

**QUESTION 5 · EXAM SCENARIO**

**HR and guest Wi-Fi devices are connected to the same physical switch, but the company must separate their traffic and apply different security policies without buying another switch. Which technology should be configured?**

**A)** VLANs

**B)** VPN concentrator

**C)** DMZ

**D)** Honeypot

**QUESTION 6 · EXAM SCENARIO**

**A company must make its public DNS server and email gateway reachable from the internet while keeping internal database and file servers hidden. Which network placement is MOST appropriate for the public DNS and email gateway?**

**A)** Internal server VLAN

**B)** Screened subnet

**C)** VPN address pool

**D)** Management VLAN

**QUESTION 7 · EXAM SCENARIO**

**A developer asks to connect a test lab to the production network so the lab can pull real customer data. The security manager is concerned about new paths into production. What is the BEST first step?**

**A)** Allow the connection because the lab is inside the company building

**B)** Connect the lab through an encrypted tunnel with no firewall rules

**C)** Place the lab in a separate security zone and allow only the minimum required data flows

**D)** Disable logging on the lab connection to reduce alert noise

**QUESTION 8 · EXAM SCENARIO**

**Remote users connect through the company VPN concentrator. Some laptops may be compromised before connecting. Which design BEST limits the risk that a compromised remote endpoint can reach sensitive internal systems?**

**A)** Assign all VPN users IP addresses on the internal server VLAN

**B)** Terminate VPN users in a dedicated security zone and permit only required internal destinations

**C)** Enable split tunneling so VPN traffic bypasses internal firewall inspection

**D)** Allow VPN users to access all internal subnets after authentication

**QUESTION 9 · EXAM SCENARIO**

**A public web server in the DMZ must read data from an internal database server. The firewall team needs a rule that supports the application while limiting exposure. Which rule is MOST appropriate?**

**A)** Allow any source in the DMZ to any destination in the internal network

**B)** Allow the specific database port from the web server IP address to the database server IP address

**C)** Allow RDP from the DMZ to all domain controllers

**D)** Allow all internal hosts to initiate sessions to the DMZ

**QUESTION 10 · EXAM SCENARIO**

**A company wants to learn how attackers probe its internet-facing services. The security team sets up isolated decoy systems that look like real servers, but contain no production data. What is the PRIMARY purpose of this infrastructure?**

**A)** Divert attackers and collect intelligence about their techniques

**B)** Provide high-availability web services to customers

**C)** Store encrypted backups for disaster recovery

**D)** Route VPN traffic between branch offices

## ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

**Question 1: Option B — In a screened subnet, with firewall rules allowing only required application traffic to the database**

A screened subnet (DMZ) is designed for internet-facing services. It isolates public systems from the internal network and allows only specific, required traffic from the web server to the database, reducing exposure of internal assets.

**Question 2: Option B — Restrict the portal to the management network or VPN and close unnecessary public inbound ports**

Reducing attack surface means eliminating unnecessary exposure. Limiting the admin portal to the management network/VPN and closing public inbound ports removes internet-wide reachability while preserving controlled administrative access.

**Question 3: Option A — VPN concentrator**

A VPN concentrator is designed to handle many simultaneous VPN connections, centralize authentication, and route remote-user traffic securely into the network. It is not a honeynet, a segmented zone, or a trunking protocol.

**Question 4: Option A — Honeynet**

A honeynet is a network of decoy systems intended to attract and monitor attackers. It provides intelligence and early warning while keeping production assets separate.

**Question 5: Option A — VLANs**

VLANs logically segment a switch into separate broadcast domains. They allow HR and guest traffic to be isolated and governed by different policies even when they share physical hardware.

**Question 6: Option B — Screened subnet**

Public-facing services such as DNS and email gateways belong in a screened subnet/DMZ. This allows controlled external access while protecting internal servers behind additional firewall restrictions.

**Question 7: Option C — Place the lab in a separate security zone and allow only the minimum required data flows**

New connectivity creates new risk. Segmenting the lab into its own security zone and allowing only required traffic follows least privilege and limits the attack surface between the lab and production.

**Question 8: Option B — Terminate VPN users in a dedicated security zone and permit only required internal destinations**

Putting VPN clients into a dedicated security zone and applying firewall rules to only required destinations limits lateral movement from a compromised endpoint. Direct placement on internal server VLANs or full internal access increases risk.

**Question 9: Option B — Allow the specific database port from the web server IP address to the database server IP address**

The most secure rule permits only the specific service, source, and destination required. Broad any-to-any or administrative protocols from the DMZ to internal systems greatly increase risk.

**Question 10: Option A — Divert attackers and collect intelligence about their techniques**

Honeypots/honeynets are decoy systems used to attract attackers, detect activity, and gather intelligence. They should not provide production services or store real sensitive data.